

SVKM'S NMIMS
MUKESH PATEL SCHOOL OF TECHNOLOGY MANAGEMENT & ENGINEERING

Academic Year: 2023-2024

Program: BTech (CSE) Stream: CyberSecurity

Subject: Application Security Testing

Date: 28/June/2024

Marks: 100

Year: 2023-24 Semester: VI

Time: 3 hrs (2 to 5pm)

No. of Pages: 02

ReExamination

Instructions: Candidates should read carefully the instructions printed on the question paper and on the cover of the Answer Book, which is provided for their use.

- 1) Question No. 1 is compulsory.
- 2) Out of remaining questions, attempt any 4 questions.
- 3) **In all 5 questions to be attempted.**
- 4) All questions carry equal marks.
- 5) **Answer to each new question to be started on a fresh page.**
- 6) **Figures in brackets on the right-hand side indicate full marks.**
- 7) **Assume Suitable data if necessary.**

Q1		Answer briefly:	
CO-1; SO-1; BL-2; U1	a.	Infer the need for securing information and comment on any TWO Information Security Attack Vectors.	[05]
CO-1; SO-1; BL-2; U2	b.	Describe the BSIMM Framework for assessing the Secure Software Lifecycle.	[05]
CO-3; SO-4; BL-3; U3	c.	Comment on the reasons for Race Condition Vulnerability.	[05]
CO-2; SO-1; BL-2; U5	d.	Infer BYOD Risks.	[05]
Q2 CO-1; SO-1; BL-4; U1	a.	Working and Significance of MVC Architecture compared with Single-page Architecture.	[10]
Q2 CO-2; SO-1; BL-1; U4	b.	Specify the three types of XSS attacks and specify the distinct steps of their working?	[10]

Q3 CO-2; SO-1; BL-3; U3	a.	Comment on Static Detection techniques and relate to how and which vulnerability it helps in detecting.	[10]
Q3 CO-3; SO-4; BL-4; U4	b.	Difference between CSRF and SSRF attacks wrt their working.	[10]
Q4 CO-1; SO-1; BL-2; U2	a.	Infer the need for adaptation of SecSDL to Payment Card Industry (PCI).	[10]
Q4 CO-2; SO-1; BL-1; U5	b.	Explain Smishing and its reasons of being effective. What is Mobile Spam?	[10]
Q5 CO-2; SO-1; BL-2; U3	a.	How would runtime detection help in mitigating structured output generation vulnerabilities.	[10]
Q5 CO-3; SO-1; BL-1; U5	b.	Describe general guidelines for Mobile Platform Security.	[10]
Q6 CO-1; SO-1; BL-4; U1	a.	Compare between WAF, RASP, CNAPP application security tools and solutions.	[10]
Q6 CO-2; SO-1; BL-1; U4	b.	Explain FIVE types of SQLi Injection.	[10]
Q7 CO-1; SO-1; BL-1; U2	a.	Explain the SDL practices incorporated by Microsoft to improve the security of their products.	[10]
Q7 CO-3; SO-4; BL-4; U4	b.	Differentiate Bluesnarfing and Bluebugging and describe advantages of Multi-factor Authentication.	[10]